Project Report: Securing the Digital Marketplace: Strengthening Security for Vulnerable Websites

Student Name: Mohammad Aamir Siddique

Target Environment: Practice Labs (Kali Linux & Metasploitable/DVWA)

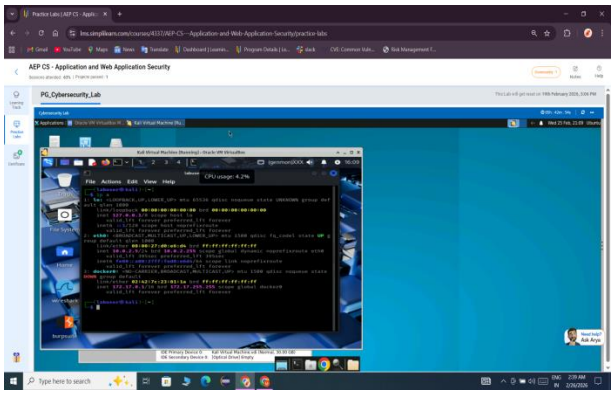
---

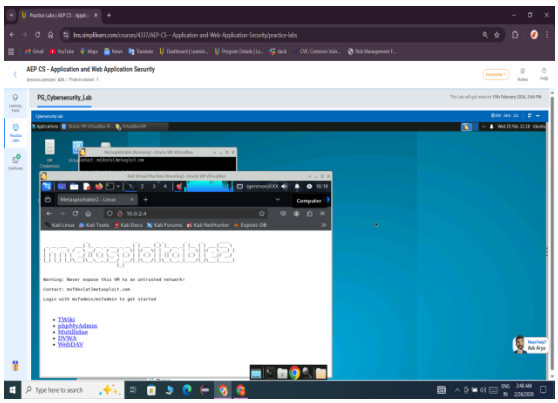
1. Introduction

An e-commerce business preparing to launch a new website identified potential critical vulnerabilities within its infrastructure. The objective of this project was to conduct a comprehensive security review, simulate real-world attacks to identify high-risk vulnerabilities (such as SQL Injection and Cross-Site Scripting), and evaluate key features for weaknesses. By acting as an ethical hacker, the goal was to uncover sensitive data exposure and implement measures to enhance the website's overall security resilience before deployment.

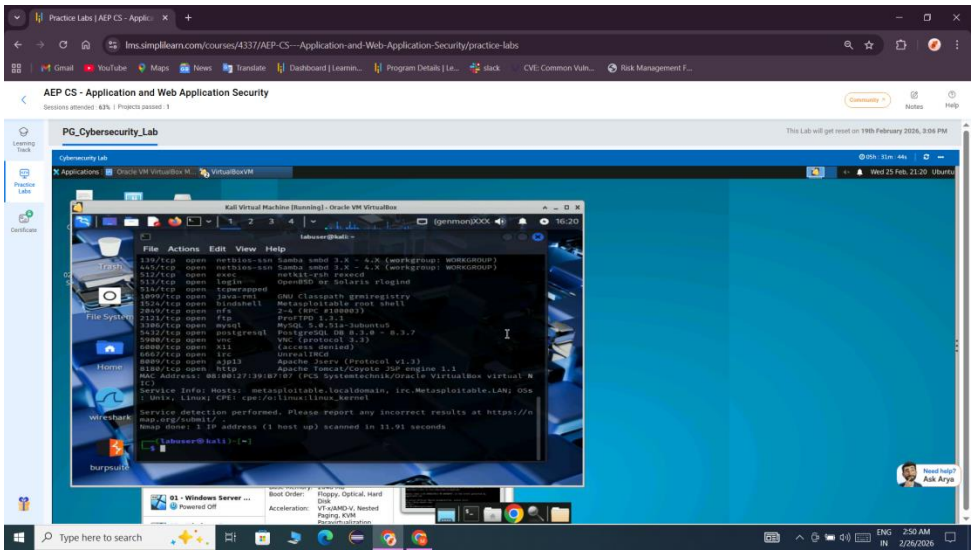
2. Execution Steps & Technical Findings

Step 1: Environment Setup and Identification The security assessment began by establishing the testing environment. The attacker machine (Kali Linux) was identified on the network at `10.0.2.5`, and the vulnerable e-commerce web server (hosted on Metasploitable) was located at `10.0.2.4`.

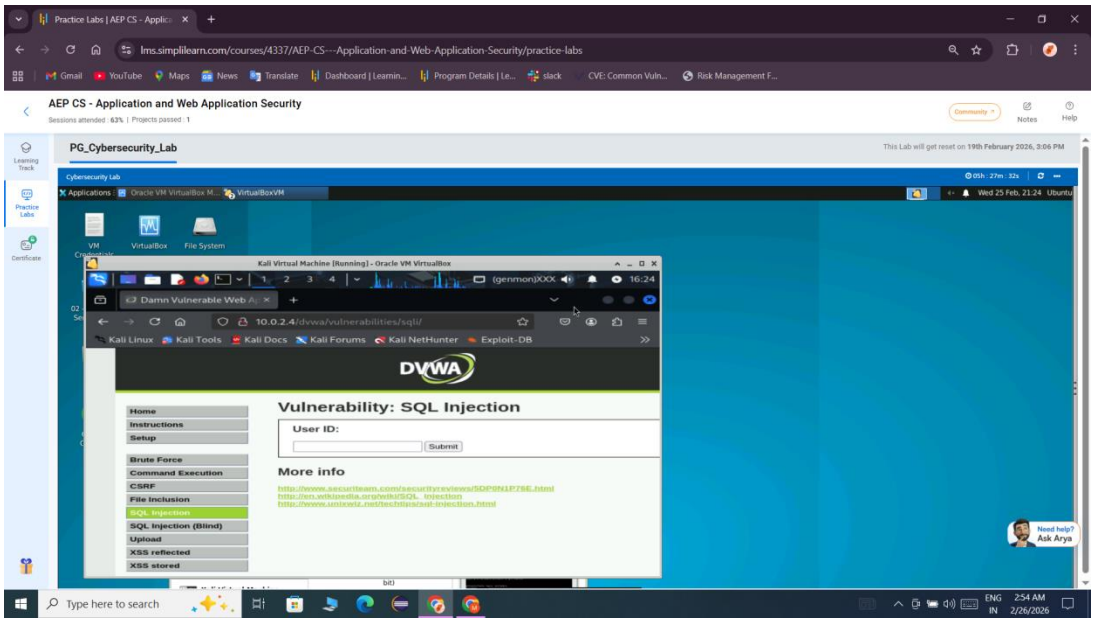




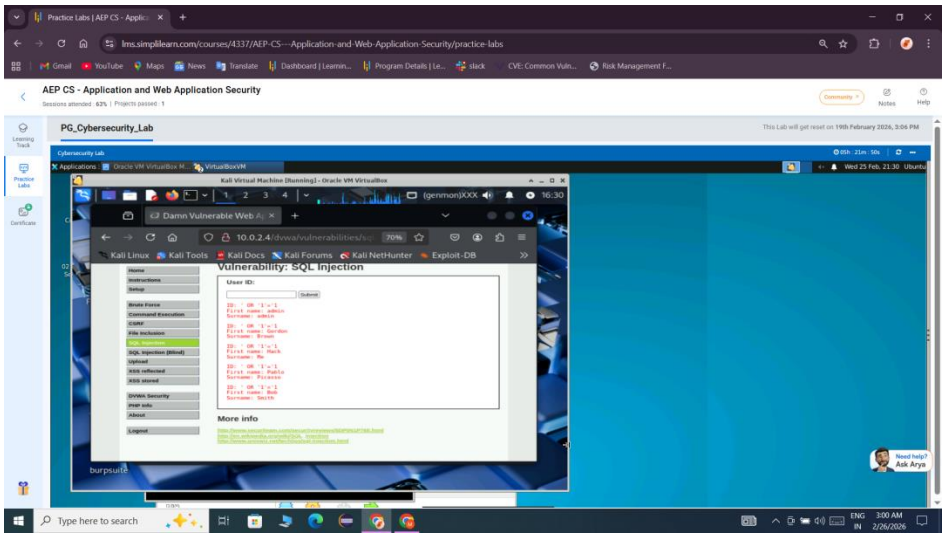
Step 2: Network Reconnaissance (Nmap) To identify potential entry points, a comprehensive network scan was performed using Nmap (`nmap -sV`). The scan revealed open ports and services, specifically confirming that Port 80 (HTTP) was open and running an Apache web server, exposing the platform to web-based attacks.



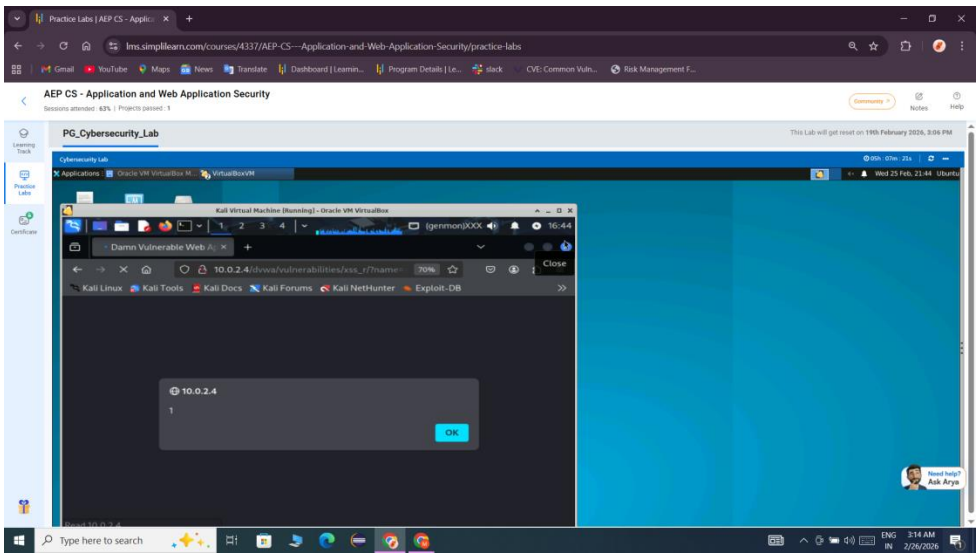
Step 3: Vulnerability Identification (SQLi) During the evaluation of the website's features, the "User ID" input field was identified as highly suspicious. The lack of proper input validation indicated a strong potential for database manipulation.



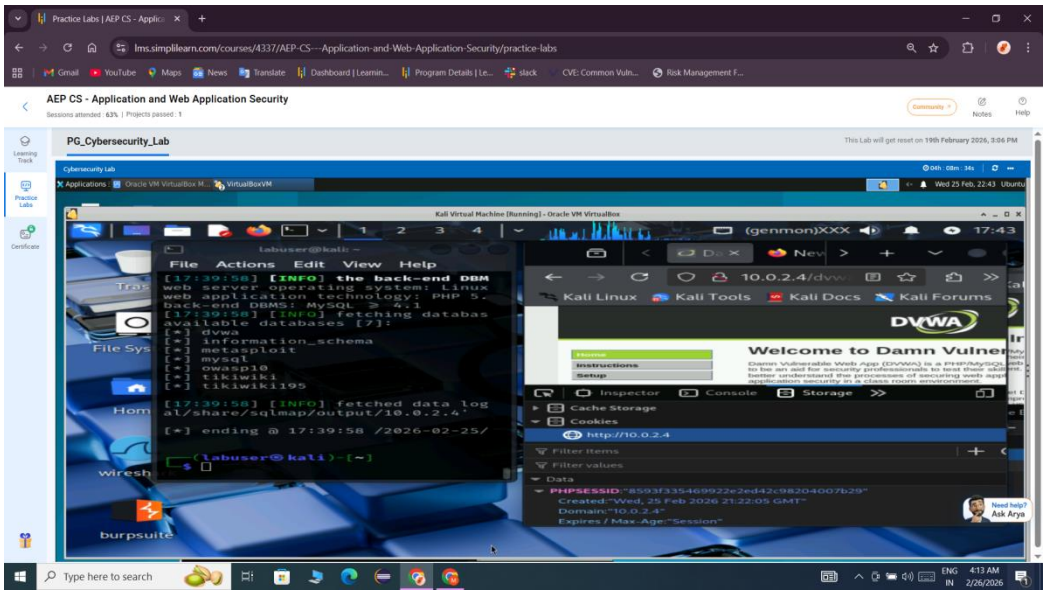
Step 4: Manual SQL Injection (Sensitive Data Exposure) A manual SQL injection attack was simulated to test the database's access controls. By injecting the payload `' OR '1'='1` into the User ID field, the authentication mechanism was bypassed. This resulted in a severe sensitive data exposure incident, as the database erroneously dumped the records of all registered users on the platform.



Step 5: Cross-Site Scripting (XSS) Exploitation The platform was further tested for frontend vulnerabilities. A JavaScript payload (`<script>alert(1)</script>`) was injected into a user prompt. The server reflected this script back to the browser, successfully executing it. In a real-world scenario, this vulnerability could lead to session hijacking and unauthorized access to user accounts.



Step 6: Automated Detection & Exploitation (SQLmap) To fully assess the extent of the database vulnerability, the attack was automated using SQLmap. By leveraging an active session cookie, SQLmap systematically exploited the SQL injection flaw, completely bypassing access controls and extracting the names of all backend databases (including `dvwa` and `information_schema`).



---

3. Remediation & Mitigation Strategies

To address these findings and secure the platform, the development team must implement the following defenses:

- **Input Validation & Secure Queries:** To mitigate the SQL Injection risks, the application must immediately transition to using parameterized queries (prepared statements). This ensures user input is strictly treated as data and cannot manipulate database logic.
- **Robust Access Controls & Output Encoding:** To neutralize the XSS vulnerabilities, strict input validation and HTML output encoding must be implemented so that malicious scripts are neutralized before they can be executed by a user's browser.

4. Conclusion

This security review successfully simulated real-world cyber threats against the e-commerce platform. Utilizing industry-standard tools like Kali Linux, Nmap, and SQLmap, the assessment uncovered critical flaws, including SQL Injection and Cross-Site Scripting, which led to unauthorized access and sensitive data exposure. By implementing the recommended fixes—such as secure queries and input validation—the development team can effectively address these weaknesses. After implementing these fixes, the website should undergo a final security review to confirm its resilience against future cyber threats prior to launch.